

Internal Security Audit — Controls and Compliance

Assessment (NIST CSF) | Botium Toys Case Study

Executive Summary

This internal security audit evaluates the security posture of Botium Toys using the NIST Cybersecurity Framework (NIST CSF). The assessment reviewed organizational controls, regulatory compliance requirements (PCI DSS, GDPR, and SOC), and operational risks affecting critical assets and business continuity.

The audit identified significant gaps in access control, encryption, disaster recovery planning, and compliance implementation. While some physical and technical safeguards are in place, improvements are required to reduce regulatory risk exposure and strengthen overall cybersecurity resilience.

Controls assessment checklist

Yes	No	Control
	•	Least Privilege
	•	Disaster recovery plans
	•	Password policies
	•	Separation of duties
•		Firewall
	•	Intrusion detection system (IDS)
	•	Backups
•		Antivirus software
•		Manual monitoring, maintenance, and intervention for legacy systems
	•	Encryption
	•	Password management system
•		Locks (offices, storefront, warehouse)
•		Closed-circuit television (CCTV) surveillance
•		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
		• Only authorized users have access to customers' credit card information. • Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. • Implement data encryption procedures to better secure credit card transaction touchpoints and data. • Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
		• E.U. customers' data is kept private/secured. • There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. • Ensure data is properly classified and inventoried. • Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
		• User access policies are established. • Sensitive data (PII/SPII) is confidential/private. • Data integrity ensures the data is consistent, complete, accurate, and has been validated. • Data is available to individuals authorized to access it.

Recommendations to the IT Manager

Recommendations Summary

Based on the internal security audit, Botium Toys currently faces a high level of risk due to missing administrative, technical, and compliance controls. The following actions are recommended to improve the organization's security posture and reduce operational, legal, and financial risks.

1. Implement Strong Access Control Measures

- Enforce **least privilege access** so employees only access data required for their roles.
- Implement **separation of duties** to reduce insider threats.
- Establish formal **user access management policies** and periodic access reviews.

Risk Reduced: Unauthorized access to customer data and internal systems.

2. Protect Sensitive Data with Encryption

- Encrypt customer payment information during storage, processing, and transmission.
- Apply encryption to databases containing PII/SPII and cardholder data.

Risk Reduced: Data breaches, PCI DSS violations, and regulatory fines.

3. Strengthen Authentication and Password Security

- Update password policies to meet modern complexity standards.
- Deploy a **centralized password management system**.
- Consider implementing **multi-factor authentication (MFA)** for employees and administrators.

Risk Reduced: Account compromise and credential-based attacks.

4. Improve Monitoring and Threat Detection

- Implement an **Intrusion Detection System (IDS)** to monitor suspicious network activity.
- Establish continuous monitoring procedures for legacy systems.
- Maintain regular antivirus updates and system patching schedules.

Risk Reduced: Undetected cyberattacks and prolonged security incidents.

5. Establish Backup and Disaster Recovery Capabilities

- Create and test a **disaster recovery plan**.
- Implement automated backups of critical business and customer data.
- Store backups securely and test recovery procedures regularly.

Risk Reduced: Business downtime and permanent data loss.

6. Enhance Compliance with Security Regulations

- Align security controls with **PCI DSS**, **GDPR**, and **SOC** best practices.
- Perform asset inventory and data classification activities.
- Ensure only authorized personnel access cardholder and customer data.

Risk Reduced: Regulatory penalties and reputational damage.

7. Maintain and Formalize Physical Security Controls

- Continue maintaining locks, CCTV monitoring, and fire detection systems.
- Document physical security procedures as part of organizational policy.

Risk Reduced: Physical theft, tampering, and environmental damage.

Final Recommendation

Botium Toys should prioritize implementing access controls, encryption, monitoring solutions, and disaster recovery planning immediately. Addressing these gaps will significantly reduce risk exposure, improve compliance readiness, and support secure business growth as the company expands globally.